Ce qu'il ne faut pas faire

- Contractualiser avec un développeur pour la réalisation d'une application sans formaliser avec lui les objectifs et les mesures techniques attendus en termes de sécurité des données et sans préciser que ces exigences sont applicables aux sous-traitants ultérieurs (voir la fiche n°14 - Gérer la sous-traitance).
- Intégrer ou laisser à son sous-traitant la latitude d'intégrer dans son application des éléments de code extérieurs (ou SDK), y compris ceux proposés par les éditeurs des systèmes d'exploitation mobiles, sans s'assurer qu'ils respectent eux-mêmes les précautions de sécurité à l'état de l'art.

POUR ALLER PLUS LOIN

- De manière générale, respecter les niveaux L1 et L2 des recommandations produites par l'OWASP[124].
- **Le modèle de sécurité des applications mobiles ne devrait pas se reposer sur l'intégrité du terminal (via une attestation mise à disposition par le système d'exploitation)**, sauf dans certains cas justifiés. Le service devrait être conçu de manière à maintenir le niveau de sécurité même avec des terminaux considérés corrompus. **Les bonnes pratiques en termes d'API** (voir la fiche n°25 - API : Interfaces de programmation applicative) **devraient être appliquées pour sécuriser les serveurs utilisés par l'application et les protéger contre des éventuelles tentatives d'abus**.
- Privilégier le traitement et le stockage des données de l'utilisateur directement sur son terminal.
- Il est souhaitable que **l'éditeur d'une application mette en place un processus de validation de toutes les modifications apportées au traitement mis en œuvre, notamment en termes de sécurité**, afin d'éviter que des évolutions (ex. : opérations de maintenance, modification de composants externes) ne viennent impacter la sécurité globale du traitement.
- Il est important de mettre en œuvre des processus qui assurent le maintien de la sécurité de l'application au cours du temps, notamment :
  - en adoptant une méthodologie d'intégration et de déploiement continus (CI/CD en anglais) pour permettre des mises à jour fréquentes des applications, notamment en cas de mise à jour de sécurité ;
  - en informant les utilisateurs de la disponibilité de mises à jour critiques (ex. : un bandeau d'information), **voire en bloquant certaines fonctionnalités au niveau du serveur pour les versions non sécurisées de l'application** ;
  - en maintenant **la vigilance relative aux éléments externes intégrés dans les applications**, notamment face au risque d'évolution malveillante dans les SDKs ou les bibliothèques utilisés, via des pratiques de sécurisation de la chaîne d'approvisionnement (ou « *supply-chain security* ») tel que décrit dans les analyses de l'ANSSI[125] ;
  - en s'assurant que le niveau de sécurité attendu puisse rester le même, le plus longtemps possible, indépendamment de la version de l'OS utilisée. De sorte qu'un utilisateur qui ne souhaiterait ou ne pourrait pas accéder à un appareil récent puisse bénéficier d'un niveau de sécurité suffisant.

124 Open web application security project (voir « OWASP MAS Checklist », mas.owasp.org).

125 « Chaine d'attaque sur les prestataires de service et les bureaux d'étude : un nouveau rapport d'analyse de la menace », cyber.gouv.fr